Sécurité de FasoSouverain

Architecture effective

Le navigateur chiffre et déchiffre les messages avec le moteur Rust/WASM de `matrix-js-sdk`. Les messages de salon utilisent Megolm ; les échanges de clés entre appareils utilisent Olm. Les fichiers et vocaux sont chiffrés avant leur téléversement avec la bibliothèque Matrix de pièces jointes. Aucune clé n'est dérivée d'un identifiant de salon.

Le portail n'expose aucun jeton Synapse au navigateur. Les jetons restent dans un registre chiffré sur une base PostgreSQL dédiée. La passerelle `/matrix/` vérifie la session du portail, un cookie HttpOnly SameSite=Strict, la preuve de possession et l'état de l'agent. Sa liste de chemins autorisés exclut connexion directe, API d'administration, invitations libres, création de salons libre et messages en clair. Le module Synapse `secure_rooms.SecureRooms` rejette aussi les messages en clair et les suppressions du chiffrement.

Le contrôle TOTP est obligatoire avant tout accès à Matrix. Les tentatives sont limitées. Le secret TOTP est conservé chiffré côté serveur, comme dans un système TOTP classique : l'expression « zero knowledge » ne s'applique pas à ce secret. Le QR de configuration est transmis uniquement avant validation de l'enrôlement. Le compte de service Synapse dispose des droits nécessaires au provisioning ; les comptes des agents créés par le portail ne reçoivent pas de droits d'administration Synapse.

La preuve `X-Faso-DPoP` est un protocole applicatif utilisant ECDSA P-256 et les empreintes JWK RFC 7638. Elle n'est pas un JWT DPoP conforme à RFC 9449. La clé WebCrypto privée est non exportable et persistée dans IndexedDB pour la reprise de session ; cela ne garantit pas un stockage matériel ni une protection contre un script malveillant exécuté dans l'origine de l'application.

Contrôles métier

Les rôles du portail contrôlent l'enrôlement, la révocation, les invitations, les relations entre administrations, les classifications déclarées et les instructions. Le contenu métier est chiffré ; une enveloppe minimale de classification, instruction et expiration reste visible pour permettre les contrôles serveur. Le serveur ne peut pas analyser le sens d'un texte chiffré ni empêcher un agent de divulguer ce qu'il a déjà lu.

Les accusés HMAC sont signés par le serveur sur l'identifiant d'événement, l'identité de l'agent et l'horodatage. Ils permettent une vérification d'intégrité serveur ; ils ne sont pas des signatures personnelles assurant une non-répudiation envers l'administrateur qui détient le secret HMAC.

La révocation est enregistrée avant l'appel Synapse : les sessions du portail sont coupées immédiatement, puis Synapse désactive le compte et organise sa sortie des salons. Les intentions inachevées sont reprises au démarrage. Les clients Matrix renouvellent leurs sessions sortantes quand les membres changent. Les clés ou messages déjà reçus ne peuvent pas être retirés rétroactivement.

Récupération et limites

Les clés Matrix locales sont conservées dans IndexedDB. Un verrou d'onglet empêche deux clients simultanés de modifier le même stockage cryptographique. La sauvegarde des clés est chiffrée côté client et la clé de récupération doit être conservée par l'agent hors du navigateur. Un nouvel appareil peut restaurer ces clés ou effectuer une vérification par comparaison de codes.

La purge efface les clés Matrix locales et demande la désactivation du compte. Un échec réseau est signalé : l'effacement local seul ne constitue pas une confirmation de révocation serveur. Les sauvegardes cryptographiques et les copies déjà présentes sur un autre appareil ne sont pas supprimées.

Le TTL masque le message dans cette interface, sans garantir l'effacement des événements chiffrés ou des sauvegardes. La limitation de sélection de texte ne bloque pas captures d'écran, outils de développement ou photographie de l'écran. Les badges d'état proviennent du SDK et ne représentent aucune certification externe.

Exploitation

Seul le portail est publié sur localhost. Déployer HTTPS avant un usage distant, activer `COOKIE_SECURE`, conserver Synapse et PostgreSQL sur le réseau interne et protéger les volumes de secrets. Ne pas exposer un client Matrix direct qui contournerait la 2FA du portail. Le mode démo est explicitement activé et doit rester réservé aux données fictives.

Le serveur connaît membres, noms de salons, identités, classifications, expirations, horodatages et tailles des échanges. Présence, aperçu d'URL, fédération et télémétrie sont désactivés. La rétention des IP Synapse est fixée à un jour ; les journaux du proxy et du portail doivent avoir leur propre politique de conservation.

Le registre PostgreSQL est versionné et chiffré AES-256-GCM avec un secret persistant distinct de la clé de signature du portail. Sauvegarder les deux bases, médias, clés Synapse et volume `bootstrap` ensemble. Le portail ne prend en charge qu'une instance active, imposée par verrou PostgreSQL. La consultation des compteurs d'événements utilise un rôle SQL distinct limité à `SELECT` sur `events`.